

DOSSIER TÉCNICO

LexCRM

Ingeniería y Manejo de Datos

Arquitectura del sistema, seguridad de la información y cumplimiento de la Ley N° 21.719 de Protección de Datos Personales de Chile.

Índice

01 Resumen ejecutivo

02 Arquitectura de ingeniería

03 Modelo de datos y multi-tenancy

04 Seguridad de la información

05 Cumplimiento de la Ley N° 21.719

06 Tratamiento de datos de causas penales

07 Derechos de los titulares (ARCO+)

08 Módulo de Inteligencia Artificial

09 Unidad económica y escalabilidad

10 Transparencia técnica: limitaciones actuales

11 Roadmap técnico

Resumen ejecutivo

LexCRM es un sistema de gestión legal en modalidad SaaS (Software as a Service) diseñado específicamente para abogados independientes y estudios jurídicos pequeños en Chile. Cubre el ciclo completo de operación de un estudio: captación de prospectos, gestión de clientes y causas, plazos procesales, citas, documentos, honorarios y tareas, con un módulo de inteligencia artificial para generación de resúmenes ejecutivos y borradores de escritos.

Tesis técnica en una frase

Arquitectura serverless moderna con costo marginal por cliente cercano a cero, y cumplimiento de la Ley N° 21.719 **construido dentro del producto** — no como una promesa de política, sino como funcionalidades verificables en el código — anticipándose a la entrada en plena vigencia de la ley (diciembre 2026), cuando la demanda de proveedores "compliant" por parte de estudios jurídicos se convertirá en requisito de compra.

10

módulos funcionales en
producción

~\$0–5

USD/mes de
infraestructura por
cliente en volúmenes
iniciales

AES-256

cifrado a nivel de
aplicación para datos
sensibles

Dic 2026

vigencia plena Ley
21.719 — ventana de
oportunidad

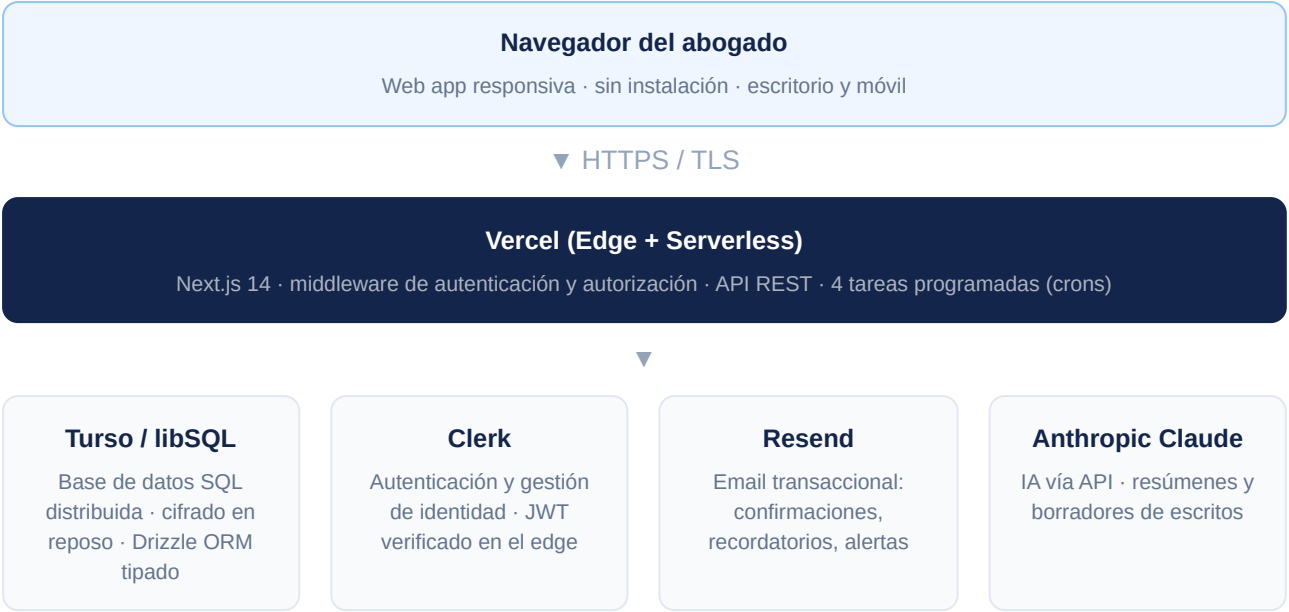
Por qué importa el ángulo regulatorio

Un CRM jurídico no maneja datos genéricos: almacena datos sensibles (salud, situación socioeconómica), datos de obligaciones económicas y — en el caso de abogados penalistas — datos de infracciones penales, que la ley califica de **carácter reservado** con prohibición expresa de tratamiento masivo. El proveedor del software actúa como **encargado de tratamiento** (Art. 15 bis): si excede el encargo, responde como responsable, con multas de hasta 20.000 UTM (gravísimas). LexCRM fue diseñado para operar dentro de ese marco desde su arquitectura, no adaptado a posteriori.

Estado actual: producto en producción en lexcrm.site, con onboarding manual de clientes de pago, sociedad legal constituida e iniciación de actividades en trámite ante el SII.

Arquitectura de ingeniería

LexCRM es una aplicación web full-stack construida sobre un stack moderno, 100% serverless y de tipo *managed services*: no hay servidores propios que administrar, parchar ni escalar manualmente.



Componentes y decisiones de diseño

Capa	Tecnología	Racional
Framework	Next.js 14 (App Router) + TypeScript	Renderizado en servidor (los datos nunca se exponen en APIs públicas innecesarias), tipado estático de extremo a extremo
Hosting	Vercel	Despliegue continuo desde Git, escalado automático, HTTPS/SSL gestionado, cero operación de servidores
Base de datos	Turso (libSQL) + Drizzle ORM	SQL relacional con integridad referencial; ORM tipado que elimina clases enteras de errores de acceso a datos
Autenticación	Clerk	Gestión de identidad delegada a un especialista: hashing de contraseñas, MFA, recuperación de cuenta, sesiones JWT
Email	Resend	Entregabilidad gestionada para confirmaciones de citas, recordatorios diarios y alertas al operador
IA	API de Anthropic (Claude)	Sin infraestructura propia de ML; pago por uso; sin entrenamiento sobre datos de clientes

Automatización programada (crons)

- **Resumen diario** por correo al abogado: citas de hoy y mañana, plazos y tareas próximos, honorarios vencidos.
- **Recordatorio nocturno** de las citas del día siguiente.
- **Aviso de tareas pendientes** dos veces al día (mañana y mediodía, hora de Chile).

Todos los endpoints de cron están protegidos por un secreto de autorización (**Bearer** token) — no son invocables públicamente.

Modelo de datos y multi-tenancy

Esquema relacional

La base de datos consta de **12 tablas** organizadas alrededor del flujo real de trabajo de un estudio jurídico:

Tabla	Contenido
clientes	Fichas de clientes del abogado (RUT único, tipo persona natural/jurídica, contacto)
causas	Expedientes: ROL, tribunal, tipo, estado, carátula, fecha de prescripción (penales)
actuaciones	Avances de cada causa, con compromisos y recordatorios al cliente
plazos	Plazos procesales: audiencias, vencimientos, notificaciones, presentaciones
documentos	Metadatos de archivos asociados a causas
honorarios	Cobros y gastos, con estados pendiente/parcial/pagado/anulado
tareas	Pendientes propios o derivados a terceros (con credenciales de portal cifradas)
citas	Reuniones con clientes o prospectos (presencial, Meet, Zoom, telefónica)
prospectos	Embudo comercial: contacto → reunión → propuesta → ganado/perdido
perfil_abogado	Datos de contacto y bancarios del abogado (campos sensibles cifrados)
solicitudes_acceso	Intentos de acceso no autorizados, con control anti-spam de notificaciones
registros_auditoria	Bitácora de exportaciones y eliminaciones de datos

Aislamiento multi-tenant a nivel de fila

Cada tabla de negocio incluye una columna `user_id` con el identificador del abogado dueño de los datos. **Toda consulta del sistema filtra obligatoriamente por ese identificador**, verificado contra el token de sesión en el servidor. Un abogado no puede — ni por error ni por manipulación de la interfaz — acceder a datos de otro.

Integridad referencial

Las relaciones entre tablas están declaradas con claves foráneas y reglas de borrado en cascada (`ON DELETE CASCADE`) o desvinculación (`ON DELETE SET NULL`), **activadas y verificadas en runtime**. Eliminar un cliente elimina de forma consistente todas sus causas, actuaciones, plazos, documentos, honorarios y tareas — sin registros huérfanos. Esta garantía fue probada de forma dirigida (test de cascada completa) antes de su despliegue a producción.

Migraciones idempotentes: el esquema evoluciona mediante migraciones que pueden ejecutarse repetidamente sin efectos secundarios, lo que permite desplegar actualizaciones sin ventanas de mantención.

Seguridad de la información

Cifrado en capas

Capa	Mecanismo	Qué protege
En tránsito	HTTPS / TLS en todo el tráfico	Toda comunicación navegador ↔ servidor ↔ servicios
En reposo (infraestructura)	Cifrado del proveedor de base de datos (Turso)	La totalidad de la base de datos
En reposo (aplicación)	AES-256-GCM propio de LexCRM	Campos de mayor sensibilidad: credenciales de portales de terceros (Poder Judicial, SII) y datos bancarios del abogado

El cifrado a nivel de aplicación usa una clave de 256 bits, un vector de inicialización aleatorio por registro y autenticación de integridad (GCM) — un valor alterado en la base de datos no se descifra silenciosamente mal, sino que falla de forma detectable. El formato de almacenamiento es versionado, lo que permite rotaciones de clave o cambios de algoritmo futuros sin romper datos históricos.

Gestión de secretos

Ninguna clave (API keys, secretos de sesión, clave de cifrado, tokens de base de datos) existe en el código fuente ni en el repositorio Git. Todas viven exclusivamente como variables de entorno del proveedor de hosting. El sistema está diseñado para **fallar de forma explícita** si la clave de cifrado no está configurada — nunca degrada en silencio a guardar texto plano.

Control de acceso en dos capas

- Autenticación (Clerk):** identidad verificada mediante sesión JWT, validada en el edge antes de que la petición llegue a la aplicación.
- Autorización (allowlist):** incluso autenticado, un correo debe estar expresamente autorizado por el operador para acceder. Un registro no autorizado queda bloqueado y genera una notificación automática al operador — el acceso es una decisión comercial explícita, no un efecto del registro.

Auditoría

Las operaciones de mayor impacto — exportación masiva de causas, exportación completa de los datos de un cliente y eliminación de clientes — quedan registradas en una bitácora interna con usuario, acción, entidad afectada y fecha, dando trazabilidad conforme al Art. 14 quinquies de la Ley 21.719.

Cumplimiento de la Ley N° 21.719

La Ley N° 21.719 (que reemplaza a la Ley 19.628 y crea la Agencia de Protección de Datos Personales) entra en plena vigencia el **1 de diciembre de 2026**. LexCRM opera bajo el rol jurídico de **encargado de tratamiento / tercero mandatario** (Art. 2 letra x y Art. 15 bis): trata los datos por cuenta y bajo instrucciones del abogado, quien es el responsable.

Mapa de cumplimiento: artículo → medida implementada

Exigencia legal	Implementación en LexCRM
Art. 15 bis — Encargo regulado por contrato; prohibición de uso distinto al convenido	Contrato de servicios SaaS + Anexo de Tratamiento de Datos Personales (ATDP) ya redactados, con prohibición expresa de usar datos para entrenamiento de IA, marketing o cesión a terceros. Régimen de subencargo con responsabilidad solidaria.
Art. 14 bis — Deber de secreto y confidencialidad	Cláusula de confidencialidad con sobrevivencia indefinida post-contrato; acceso técnico restringido; datos sensibles cifrados incluso frente al propio equipo técnico.
Art. 14 quinquies — Medidas de seguridad técnicas y organizativas	Cifrado en tránsito y en reposo (doble capa), control de acceso en dos niveles, registro de auditoría de operaciones sensibles, respaldos del proveedor de base de datos.
Art. 14 sexies — Notificación de vulneraciones de seguridad	Obligación contractual de notificar al abogado responsable por la vía más expedita (plazo comprometido en el ATDP), con detalle de datos afectados y medidas adoptadas.
Arts. 24–25 — Datos de infracciones penales: carácter reservado, prohibición de tratamiento masivo, eliminación al prescribir	Tratamiento diferenciado implementado en el producto (ver sección 06).
Arts. 5°–9° — Derechos de los titulares (ARCO+)	Herramientas de portabilidad y supresión integradas en el producto (ver sección 07).
Título V — Transferencia internacional de datos	Infraestructura alojada en proveedores de EE.UU. (Vercel, Turso, Clerk, Resend, Anthropic), declarado con transparencia en la política de privacidad y respaldado por cláusulas contractuales y las certificaciones de dichos proveedores (SOC 2 / ISO 27001). El hosting en región con "nivel adecuado" es una palanca de diferenciación futura.

Punto clave para la tesis de inversión: estas medidas no son declaraciones de una política — son características verificables en el código y en el esquema de datos, auditables en una due diligence técnica.

Tratamiento de datos de causas penales

Los artículos 24 y 25 de la Ley 21.719 son el punto más delicado para un CRM usado por abogados penalistas: los datos relativos a la comisión y sanción de infracciones penales **revisten carácter reservado**, no pueden comunicarse a terceros salvo excepciones legales, está prohibido su **tratamiento masivo** en registros electrónicos, y deben eliminarse una vez prescrita la acción penal o cumplida/prescrita la pena.

Cómo lo resuelve LexCRM en el producto

Exigencia	Mecanismo implementado
Prohibición de tratamiento masivo	Las causas de tipo Penal quedan excluidas automáticamente de la exportación masiva (CSV/Excel) del listado de causas. La exclusión ocurre a nivel de consulta en el servidor — no es un filtro de interfaz que pueda saltarse.
Eliminación al prescribir	Campo dedicado de fecha de prescripción de la acción penal en cada causa penal, con alerta proactiva en el panel principal del abogado desde 90 días antes de la fecha, recordándole evaluar la eliminación conforme a la ley.
Trazabilidad	Toda exportación y eliminación queda en el registro de auditoría, con identificación del usuario, la acción y la fecha.
Acceso individual intacto	El trabajo normal del abogado con su causa penal (ver, editar, gestionar) no se ve limitado — la restricción aplica exclusivamente al tratamiento masivo.

Diferenciador competitivo: un CRM genérico (o uno extranjero) no distingue una causa penal de cualquier otro registro. LexCRM incorpora la distinción del régimen chileno directamente en su lógica de negocio.

Derechos de los titulares (ARCO+)

Los clientes de los abogados (titulares de los datos) pueden ejercer derechos de acceso, rectificación, cancelación, oposición, **portabilidad** y bloqueo temporal, y el abogado responsable debe responder dentro de plazos legales acotados. Como encargado, LexCRM debe proveer las herramientas para que el abogado pueda cumplir. Están integradas en el producto:

Portabilidad — "Exportar todos los datos"

Desde la ficha de cualquier cliente, un clic descarga un archivo estructurado (JSON, formato de uso común) con la totalidad de su información: ficha, causas, actuaciones, plazos, documentos, honorarios, tareas y citas. La exportación es **completa por diseño** — incluye también registros vinculados directamente al cliente sin pasar por una causa, un caso borde que los reportes tradicionales suelen omitir.

Acceso y rectificación

Toda la información es visible y editable por el abogado en la ficha del cliente y sus causas — puede responder una solicitud de acceso o corregir datos inexactos de inmediato.

Supresión — borrado real y completo

La eliminación de un cliente borra en cascada, de forma permanente y verificada, todos sus registros asociados (causas, actuaciones, plazos, documentos, honorarios, tareas). No quedan copias "lógicas" ocultas en la base de datos operativa. La acción queda registrada en la auditoría — se puede acreditar cuándo se eliminó, sin conservar los datos eliminados.

Al término del contrato

El marco contractual (ATDP) regula la devolución de los datos en formato estructurado o su supresión verificable, incluidos respaldos, a elección del abogado — con constancia formal de la gestión.

Módulo de Inteligencia Artificial

El módulo de IA es el principal diferenciador de producto frente a la gestión en planillas y a CRMs genéricos, y está construido con una postura conservadora respecto de los datos.

Capacidades actuales

- **Resumen ejecutivo de causa:** a partir de las actuaciones, plazos y tareas registrados, genera un resumen del estado del caso en segundos.
- **Borrador de escritos:** el abogado elige el tipo de escrito y agrega instrucciones; la IA genera un borrador editable.

Arquitectura y postura de datos

Aspecto	Diseño
Proveedor	API de Anthropic (modelos Claude) — sin infraestructura propia de ML que mantener
Modelo de costo	Pago por uso, costo marginal por generación del orden de fracciones de centavo de dólar
Entrenamiento	Los datos de los abogados y sus clientes no se usan para entrenar modelos — ni propios ni de terceros. La prohibición está además fijada contractualmente en el ATDP (Art. 15 bis).
Alcance	La IA es asistiva: el producto advierte expresamente que no sustituye el criterio profesional del abogado

Riesgo regulatorio gestionado: usar datos de clientes para entrenar modelos de IA de uso general convertiría al proveedor en responsable de datos para todos los efectos legales (Art. 15 bis inciso 2°), con exposición directa a multas. LexCRM excluye ese uso por arquitectura y por contrato.

Unidad económica y escalabilidad

Estructura de costos de infraestructura

Toda la infraestructura es serverless y de pago por uso, con niveles gratuitos generosos en los volúmenes de un negocio en etapa temprana:

Servicio	Función	Costo en etapa inicial
Vercel	Hosting, edge, crons	Nivel gratuito / plan base
Turso	Base de datos	Nivel gratuito holgado para cientos de usuarios
Clerk	Autenticación	Gratuito hasta 10.000 usuarios activos mensuales
Resend	Email transaccional	Nivel gratuito (miles de correos/mes)
Anthropic	IA	Pago por uso — centavos por abogado activo al mes

El costo marginal de infraestructura por cliente adicional es **cercano a cero** en los primeros cientos de clientes, contra un precio de suscripción de decenas de miles de pesos chilenos mensuales — la estructura de margen bruto característica de un SaaS bien construido.

Escalabilidad técnica

- **Cómputo:** funciones serverless que escalan automáticamente con la demanda; sin capacidad ociosa que pagar ni cuellos de botella de servidores propios.
- **Datos:** el aislamiento por `user_id` mantiene el costo de consulta proporcional a los datos de cada abogado, no al total del sistema.
- **Operación:** despliegue continuo desde Git; una actualización llega a todos los clientes simultáneamente, sin ventanas de mantención ni migraciones manuales por cliente.

Dependencias y su mitigación

El stack depende de proveedores gestionados (riesgo de vendor). Mitigaciones concretas: el esquema es SQL estándar portable (SQLite/libSQL), el ORM abstrae el motor de base de datos, y los respaldos completos (código + historial) se mantienen fuera de los proveedores. Ningún proveedor tiene lock-in de datos propietario.

Transparencia técnica: limitaciones actuales

Para una evaluación seria, tan importante como lo construido es lo que aún no existe. Estado honesto del producto a la fecha de este documento:

Limitación	Detalle	Plan
Cuentas mono-usuario	Cada cuenta autorizada es independiente: dos correos del mismo estudio no comparten clientes ni causas. No existe aún concepto de equipo ni roles.	Multiusuario con roles (vía Clerk Organizations) es el ítem principal del roadmap. El plan comercial "Firma" se retiró de la oferta hasta que exista.
Cobro manual	La suscripción se cobra por transferencia bancaria y la autorización de acceso es manual (allowlist). Viable en volúmenes iniciales; no escala a cientos de clientes.	Integración de pasarela de pago recurrente local (Flow / MercadoPago) en roadmap.
Sin certificaciones propias	LexCRM no cuenta aún con certificaciones de seguridad propias (ISO 27001, SOC 2); se apoya en las certificaciones de sus proveedores de infraestructura.	La certificación del modelo de prevención de infracciones ante la Agencia (Arts. 49–53) está identificada como meta pre-diciembre 2026.
Datos históricos pre-cifrado	El cifrado a nivel de aplicación aplica a escrituras nuevas; los escasos registros previos a su activación permanecen bajo el cifrado de infraestructura hasta su próxima edición.	Migración dirigida disponible como tarea puntual si un hito de auditoría lo exige.
Landing y app comparten dominio	El sitio de marketing existe pero aún no está publicado en el dominio raíz; la app ocupa lexcrm.site.	Separación landing (raíz) / app (subdominio) planificada como fase comercial siguiente.

Ninguna de estas limitaciones compromete la operación actual con los primeros clientes de pago; definen el uso natural del capital de una eventual inversión.

Roadmap técnico

Iniciativa	Descripción	Impacto
Multiusuario y roles	Equipos por estudio (socio, asociado, secretaria) con datos compartidos y permisos diferenciados, sobre Clerk Organizations. Es además la base del control de acceso por roles que exige el Art. 14 quinquies en organizaciones.	Desbloquea el plan "Firma" (ticket ~2× el plan individual) y estudios medianos como segmento.
Pasarela de pago recurrente	Cobro automático mensual en CLP (Flow / MercadoPago) con activación y suspensión automática del acceso.	Elimina el cuello de botella operativo del cobro manual; habilita crecimiento sin fricción.
Separación landing / app	Sitio comercial en el dominio raíz, aplicación en subdominio, con captura automática de solicitudes de acceso ya construida.	Embudo de adquisición estándar de SaaS.
Certificación Ley 21.719	Modelo de prevención de infracciones certificable ante la Agencia de Protección de Datos (Arts. 49–53).	Atenuante legal de responsabilidad (Art. 36 N°5) y argumento comercial fuerte ante estudios que litigan en áreas sensibles — en un mercado donde la demanda por proveedores certificados se activará con la vigencia plena de la ley.
Hosting regional	Evaluación de réplica o residencia de datos en región con nivel adecuado de protección.	Diferenciador para estudios grandes con políticas estrictas de residencia de datos.

Síntesis: LexCRM combina un stack moderno de costo marginal casi nulo, cumplimiento regulatorio construido en el producto antes de que la ley lo exija, y un roadmap donde cada ítem desbloquea directamente ingresos (multiusuario, cobro automático) o defensa regulatoria (certificación). La ventana de oportunidad es la vigencia plena de la Ley 21.719 en diciembre de 2026.